NIST Special Publication 800-999

Example Digital Guidelines

Authentication and Lifecycle Management

Jane Q. Example
John R. Sample

This publication is available free of charge from:
https://doi.org/10.6028/NIST.SP.800-999

Abstract

These guidelines provide technical requirements for federal agencies implementing digital identity services. They are not intended to constrain the development or use of standards outside of this purpose. This document defines technical requirements for each of the three authenticator assurance levels.

Keywords

authentication; authenticator; credential service provider; digital authentication; passwords.

Table of Contents

1 Purpose 3

2 Introduction 3

2.1 Notations 4

3 Authenticator Assurance Levels 4

References 6

1 Purpose

This section is informative. This document and its companion documents provide technical guidelines to agencies for the implementation of digital authentication. The guidelines are intended to be used by agencies that provide online services to members of the public as well as to their own employees and contractors.

The terms “SHALL” and “SHALL NOT” indicate requirements to be followed strictly in order to conform to the publication and from which no deviation is permitted. The terms “SHOULD” and “SHOULD NOT” indicate that among several possibilities one is recommended as particularly suitable [SP800-63].

2 Introduction

Authentication is the process of determining the validity of one or more authenticators used to claim a digital identity. Successful authentication provides reasonable risk-based assurances that the subscriber accessing the service today is the same as the one who accessed the service previously, as described in Section 3.

The following properties are required of every authenticator:

- The authenticator SHALL be resistant to replay attacks, as defined in Table 1.
- The verifier SHALL use approved encryption and an authenticated protected channel when requesting memorized secrets in order to provide resistance to eavesdropping and machine-in-the-middle attacks.
- Verifiers SHOULD permit claimants to use “paste” functionality when entering a memorized secret.

2.1 Notations

This guideline uses the following typographical conventions in text:

1. Specific terms in CAPITALS represent normative requirements.
2. Terms in italics represent defined terms in the glossary.

3 Authenticator Assurance Levels

In order to satisfy the requirements of a given AAL, a claimant SHALL be authenticated with at least a given level of strength to be recognized as a subscriber. The result of an authentication process is an identifier that SHALL be used each time that subscriber authenticates to that relying party.

Table 1. Summary of Requirements by AAL

Requirement	AAL1	AAL2	AAL3
Permitted authenticator types	Memorized Secret; Look-Up Secret	MF OTP Device; MF Crypto Software	MF Crypto Device
Reauthentication	30 days	12 hours, or 30 minutes of inactivity	12 hours, or 15 minutes of inactivity
Replay resistance	Not required	Required	Required

3.1 Authenticator Assurance Level 1

AAL1 provides some assurance that the claimant controls an authenticator bound to the subscriber's account. AAL1 requires either single-factor or multi-factor authentication using a wide range of available authentication technologies. Successful authentication requires that the claimant prove possession and control of the authenticator through a secure authentication protocol.

Example request sent by the verifier:

```
POST /authenticate HTTP/1.1
Host: verifier.example.gov
Content-Type: application/json

{"otp": "123456"}
```

References

[FIPS140] National Institute of Standards and Technology (2019) Security Requirements for Cryptographic Modules. (Department of Commerce, Washington, D.C.), Federal Information Processing Standards Publication (FIPS) 140-3.

[SP800-63] Grassi PA, Garcia ME, Fenton JL (2017) Digital Identity Guidelines. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-63-3.